

Propuesta de Arquitectura de Solución Cloud & Modernización de Canales Digitales

Cliente / Caso:

Banco BP — Ecosistema Digital e Integración
Híbrida

Estándares Aplicados:

Microsoft Cloud Adoption Framework (CAF) | Well-
Architected Framework | C4 Modeling Standard

Autor:

Angel Ortega

Fecha:

Septiembre 2026

Versión: 1.0

Contenido

PARTE 1: Requerimientos, Normativa, Front-End y Seguridad de Identidad	4
1. Marco Normativo y de Cumplimiento Financiero.....	4
2. Front-End: Análisis y Justificación Doble	5
A. SPA Web (Banca Web)	5
B. Aplicación Móvil Multiplataforma (Banca Móvil)	5
3. Arquitectura de Autenticación, Autorización y Onboarding	6
A. Flujo OAuth 2.0 / OpenID Connect Recomendado	6
B. Flujo de Onboarding Digital con Reconocimiento Facial	6
C. Autenticación Posterior al Onboarding (Biometría y Credenciales).....	7
4. Estrategia de Notificaciones Obligatorias (Mínimo 2 canales).....	7
PARTE 2: Capa de Integración, Patrones de Arquitectura, Microservicios y Estrategia de Datos	8
1. Capa de Integración y Entrada: Patrón API Gateway + BFF (Backend for Frontend)	8
Justificación Técnica de la Capa de Entrada.....	9
2. Desacoplamiento de Servicios y Orquestación de Transferencias.....	10
Patrón para Transferencias Interbancarias y Propias: Saga Orquestada + Compensación	10
3. Patrón de Persistencia y Caché para "Clientes Frecuentes"	11
Diseño del Patrón Híbrido: Cache-Aside + Read-Through / Write-Through.....	11
Componentes y Patrones Involucrados:.....	11
Justificación Técnica Doble de la Estrategia de Caché y Persistencia:	12
4. Diseño de la Base de Datos de Auditoría Inmutable	12
Arquitectura de Auditoría: Patrón Transaccional Outbox + Azure Service Bus + Azure Cosmos DB / Synapse	12
Principios de Diseño de la Solución de Auditoría:	13
5. Resumen de Patrones de Arquitectura Clave Utilizados en el Proyecto	14
PARTE 3: Modelado Arquitectónico C4 para Banco BP	15
1. Nivel 1: Diagrama de Contexto del Sistema (C1).....	15
Descripción de Actores y Sistemas	15
Diagrama de Contexto (C1)	16
2. Nivel 2: Diagrama de Contenedores (C2)	16
Descripción de Límites e Infraestructura	16
Diagrama de Contenedores (C2)	17
3. Nivel 3: Diagrama de Componentes (C3)	17
Foco: Microservicio de Transferencias (Saga Orchestrator).....	17

Descomposición Interna:.....	18
Diagrama de Componentes (C3)	18
PARTE 4: Infraestructura Cloud, Alta Disponibilidad (HA), Recuperación ante Desastres (DR), Seguridad Zero Trust y Gestión de Costos	19
1. Topología de Red y Arquitectura de Conectividad (Azure Landing Zone).....	19
Justificación Técnica Doble de la Red.....	19
2. Estrategia de Alta Disponibilidad (HA) y Recuperación ante Desastres (DR)	20
A. Métricas de Resiliencia Comprometidas	20
B. Matriz de Resiliencia por Componente	20
3. Modelo de Seguridad Zero Trust, Identidad y Gestión de Secretos	22
Componentes de Seguridad Implementados:	22
4. Observabilidad, Monitoreo y Auto-Healing (Excelencia Operativa).....	23
5. Estrategia de Optimización y Eficiencia de Costos (FinOps).....	24
PARTE 5: Conclusiones Técnicas y Hoja de Ruta de Adopción (Roadmap)	25

1. Resumen Ejecutivo y Enunciado del Requerimiento

- **1.1. Contexto del Negocio y Declaración del Problema:** Banco BP requiere modernizar sus canales digitales diseñando una solución desacoplada, resiliente y de alta concurrencia desplegada en Microsoft Azure, asegurando la integración híbrida con sus sistemas centrales existentes (Core Bancario Legacy y Sistema Complementario on-premises).
- **1.2. Requerimientos Funcionales y Técnicos Evaluados:**
 - **Canales Front-End:** Desarrollo de una aplicación Single Page Application (SPA) para banca web y una aplicación móvil multiplataforma con validación biométrica facial (onboarding eKYC) y autenticación segura.
 - **Notificaciones Multicanal:** Despacho obligatorio e inmediato por al menos dos canales independientes ante cualquier movimiento financiero.
 - **Capa de Servicios y Microservicios:** Desacoplamiento de tres servicios base (Datos Básicos, Movimientos y Transferencias), agregando servicios estratégicos y resolviendo transacciones interbancarias mediante transacciones compensatorias.
 - **Persistencia y Caché:** Implementación de un patrón de diseño híbrido para optimizar consultas de saldos e históricos de clientes frecuentes sin degradar el Core Bancario.
 - **Pista de Auditoría Inmutable:** Registro atómico y no repudiable de todas las operaciones del cliente bajo normativas de inmutabilidad y retención legal (WORM).
 - **Infraestructura Cloud y Continuidad Operativa:** Arquitectura de red Hub-and-Spoke, seguridad Zero Trust sin secretos expuestos y matriz de resiliencia ante desastres (RTO < 15 min, RPO = 0 transaccional).

PARTE 1: Requerimientos, Normativa, Front-End y Seguridad de Identidad

1. Marco Normativo y de Cumplimiento Financiero

1. **Protección de Datos Personales (LOPD / GDPR / LGPD):**
 - **Principio de minimización y finalidad:** Solo se solicitan y almacenan los datos estrictamente necesarios para la transacción financiera.
 - **Cifrado en tránsito y en reposo:** TLS 1.3 mandatorio en todas las capas; cifrado en reposo con claves administradas por el cliente (**Customer-Managed Keys - CMK** en Azure Key Vault respaldado por HSM FIPS 140-2 Nivel 3).

- **Manejo de PII y Datos Biométricos:** La biometría facial es considerada dato sensible de categoría especial. No se almacena la imagen facial en crudo en bases de datos relacionales; se almacena un *vector hash/template* biométrico cifrado y tokenizado, o se delega la custodia a un proveedor certificado.
- 2. **PCI-DSS (Payment Card Industry Data Security Standard v4.0):**
 - Aislamiento estricto de la zona de datos de tarjetahabientes (Cardholder Data Environment - CDE).
 - Prohibición expresa de registrar CVV/CVC o PINs en logs o trazas de auditoría.
 - Enmascaramiento de números de cuenta/tarjeta (PAN) en interfaces y reportes (primeros 6 y últimos 4 dígitos únicamente).
- 3. **Regulaciones de Supervisión Bancaria y Financiera (Superintendencia / ISO 27001):**
 - **Pista de auditoría inmutable (Non-repudiation):** Obligación de registrar toda acción (inicio de sesión, consulta, transferencia, cambio de credenciales) con marca de tiempo UTC sincronizada por NTP, IP de origen, ID de usuario y correlación de evento, sin posibilidad de alteración ni borrado (almacenamiento WORM - Write Once, Read Many).
 - **Notificación multicanal obligatoria:** La normativa financiera exige que ante cualquier movimiento monetario, el cliente reciba confirmación inmediata por un canal independiente (evitar fraudes y alertar en tiempo real).

2. Front-End: Análisis y Justificación Doble

A. SPA Web (Banca Web)

- **Opciones evaluadas:** React vs. Angular.
- **Decisión seleccionada:** React + TypeScript + Vite.
- **Justificación técnica doble:**
 1. *Ecosistema y Modularidad para Micro-frontends:* React permite desacoplar los módulos bancarios (Posición Consolidada, Transferencias, Pagos de Servicios) en micro-frontends independientes (usando Webpack Module Federation o Vite Federation). Esto permite que distintos squads desplieguen cambios sin riesgo de tumbar la aplicación web completa.
 2. *Rendimiento y Optimización de Bundle:* Frente a Angular (que incluye un framework completo y rígido con mayor peso inicial), React ofrece un Virtual DOM eficiente, tree-shaking agresivo y carga diferida (*lazy loading*) por rutas, reduciendo el First Contentful Paint (FCP) a menos de 1.2 segundos en conexiones residenciales o móviles lentas.

B. Aplicación Móvil Multiplataforma (Banca Móvil)

- **Opciones evaluadas:** Flutter vs. React Native.
- **Decisión seleccionada:** Flutter (Dart).
- **Justificación técnica:**
 1. *Consistencia de UI y Motor Gráfico Propio (Skia / Impeller):* A diferencia de React Native (que depende de un puente de comunicación "JS-to-Native

Bridge" y renderiza componentes nativos del OS que pueden variar de apariencia o comportamiento entre fabricantes Android y versiones de iOS), Flutter compila a código de máquina nativo AOT (Ahead-of-Time). Esto garantiza paridad visual 100% idéntica, alta tasa de refresco (60-120 FPS fluidos en biometría y animaciones de pago) y cero desfases de compatibilidad.

2. *Seguridad en el Runtime y Dificultad de Ingeniería Inversa*: En una app bancaria, React Native empaqueta un bundle JavaScript que, aunque esté ofuscado, puede ser extraído y analizado dinámicamente mediante herramientas como Frida. Flutter compila directamente a binario C/C++ nativo (archivos `.so` en Android y binario Mach-O en iOS), haciendo la descompilación y la inyección de código malicioso significativamente más difícil para ciberdelincuentes.

3. Arquitectura de Autenticación, Autorización y Onboarding

A. Flujo OAuth 2.0 / OpenID Connect Recomendado

- **Opciones evaluadas:**
 1. Opción 1: *Resource Owner Password Credentials (ROPC)* (Desaconsejado por IETF OAuth Security BCP).
 2. Opción 2: *Authorization Code Flow tradicional con Client Secret* (Inseguro en clientes públicos).
 3. Opción 3: **Authorization Code Flow con PKCE (Proof Key for Code Exchange - RFC 7636) + OpenID Connect (OIDC)**.
- **Decisión seleccionada: Authorization Code Flow con PKCE + OIDC.**
- **Justificación técnica:**
 1. *Protección contra ataques de interceptación en clientes públicos (SPA y Móvil)*: Las SPAs y Apps móviles son clientes públicos: no pueden custodiar de forma segura un `client_secret` (cualquiera puede descompilar la app o ver el código JS). PKCE mitiga el riesgo generando dinámicamente en el dispositivo un `code_verifier` criptográfico y su hash `code_challenge`, garantizando que solo la instancia que solicitó el código de autorización pueda canjearlo por los tokens JWT.
 2. *Separación de Identidad y Acceso con Refresh Tokens Rotativos*: Al integrar OpenID Connect, se obtiene un `id_token` (identidad del usuario firmada) y un `access_token` de corta vida (10-15 min) para la API Gateway. Los `refresh_tokens` se manejan con **Refresh Token Rotation**, donde cada uso invalida el token anterior, mitigando el robo de sesiones móviles o ataques XSS/CSRF en web.

B. Flujo de Onboarding Digital con Reconocimiento Facial

Para el enrolamiento de nuevos clientes desde la app móvil, se establece una arquitectura de confianza cero:

1. **Captura y Prueba de Vida (Liveness Detection):**
 - El SDK en Flutter interactúa con la cámara para realizar una prueba de vida activa/pasiva (detección de parpadeo, giro de cabeza, micro-expresiones) para prevenir ataques de presentación (fotos estáticas, vídeos pregrabados, deepfakes o máscaras de silicona).
2. **Validación de Documento de Identidad (OCR + Validación Oficial):**
 - Captura de anverso y reverso de la cédula/DNI, lectura OCR de datos y extracción de la fotografía oficial del chip/código de barras bidimensional.
3. **Cotejo Biométrico Facial (1:1 Matching):**
 - Comparación biométrica entre la selfie de la prueba de vida y la foto del documento de identidad.
4. **Verificación con Buró / Registro Civil:**
 - Llamada segura desde el backend bancario hacia la base de datos de la Registraduría / Registro Civil nacional.
5. **Herramientas de Industria Recomendadas:**
 - **Azure AI Vision / Face API:** Excelente integración nativa en Azure para detección de atributos, verificación facial 1:1 y verificación de vivacidad (*liveness detection* certificada iBeta Nivel 1 y 2).
 - **Proveedores Especializados en eKYC Bancario: Veriff, Onfido (Entrust) o Jumio,** que combinan biometría, verificación documental contra bases de datos criminales/Interpol y cálculo de riesgo de fraude en milisegundos.

C. Autenticación Posterior al Onboarding (Biometría y Credenciales)

Una vez enrolado:

- **Móvil (Biometría FIDO2 / BiometricPrompt / LocalAuthentication):**
 - La aplicación móvil no envía la huella o rostro a los servidores bancarios. La biometría desbloquea las claves privadas generadas en el hardware seguro del dispositivo (**Android Keystore / iOS Secure Enclave**).
 - El dispositivo firma un reto criptográfico (*nonce*) y lo envía al Identity Provider (IdP) para validar la sesión de forma 100% segura.
- **Segundo Factor y Notificaciones (MFA):**
 - Clave temporal por software (TOTP), push notification out-of-band criptográfica en el móvil registrado, o biometría pasiva basada en comportamiento del dispositivo.

4. Estrategia de Notificaciones Obligatorias (Mínimo 2 canales)

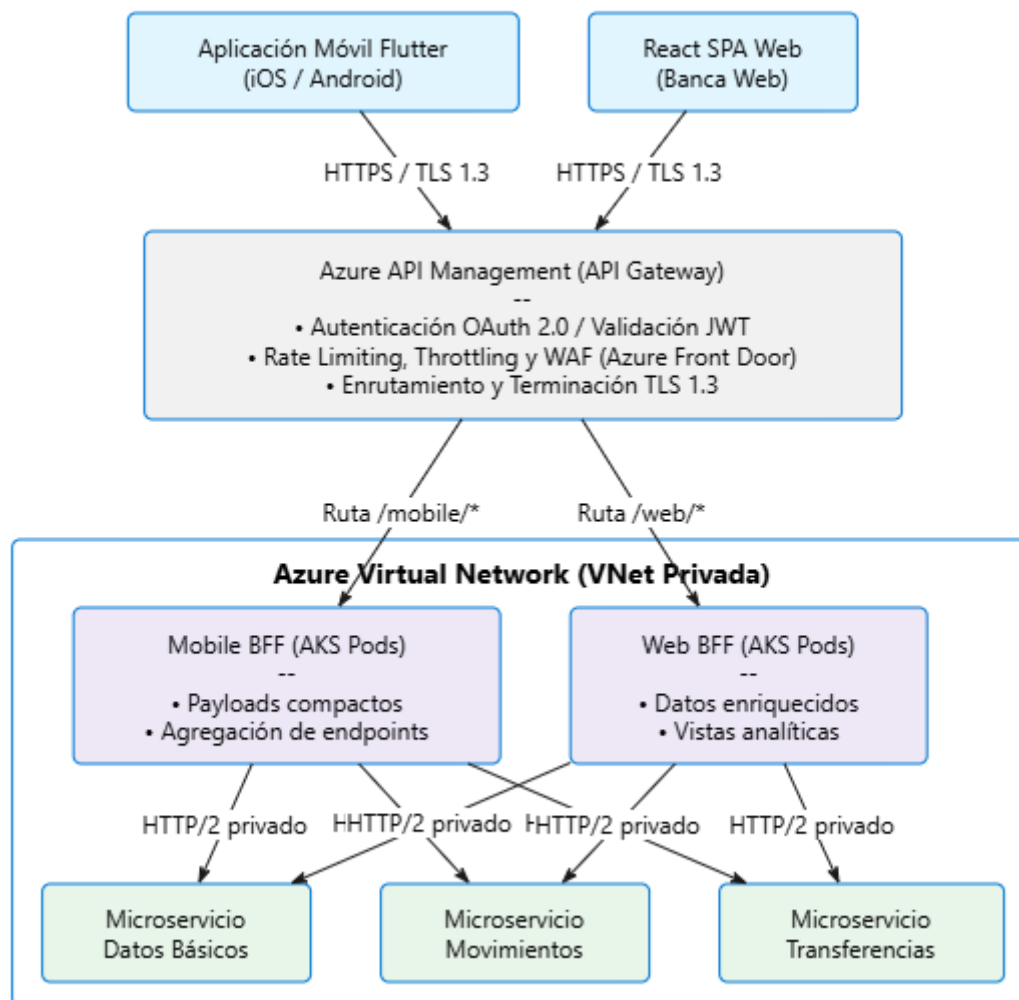
La norma exige notificación inmediata ante movimientos monetarios. La arquitectura integra:

1. **Canal 1: Notificaciones Push Móviles (In-App / Out-of-Band):**

- Implementado mediante **Azure Notification Hubs** conectado a **Firestore Cloud Messaging (FCM)** para Android y **Apple Push Notification service (APNs)** para iOS. Es instantáneo, no tiene costo de operadora telefónica y permite al usuario validar la transacción directamente en la app.
- 2. **Canal 2: Mensajería Transaccional SMS / WhatsApp:**
 - Integración con proveedores CPaaS como **Azure Communication Services (SMS)** o **Twilio / Infobip**. Se garantiza entrega inmediata en cualquier teléfono móvil aunque no tenga datos activos o no tenga la app abierta, vital para alertas antifraude inmediatas.
- 3. **Canal 3 (Complementario): Correo Electrónico Transaccional:**
 - Vía **Azure Communication Services Email** o **SendGrid**, enviando el comprobante detallado con firma digital en formato PDF.

PARTE 2: Capa de Integración, Patrones de Arquitectura, Microservicios y Estrategia de Datos

1. Capa de Integración y Entrada: Patrón API Gateway + BFF (Backend for Frontend)



Justificación Técnica de la Capa de Entrada

- **Opciones evaluadas:** Un API Gateway monolítico único vs. **Azure API Management + Patrón BFF (Backend for Frontend)** por tipo de cliente.
- **Decisión seleccionada:** **Azure API Management (Inbound/Security) + BFF desacoplado (Mobile BFF y Web BFF).**
- **Justificación técnica:**
 1. *Optimización del payload y latencia móvil:* Los dispositivos móviles sufren en redes celulares con payloads JSON sobredimensionados (*over-fetching*). El Mobile BFF realiza agregación de llamadas (*API Aggregation Pattern*), transforma y compacta las respuestas antes de enviarlas al teléfono, mientras que el Web BFF puede entregar información analítica más detallada para pantallas de escritorio.
 2. *Defensa en profundidad y desacoplamiento de versiones:* Si se actualiza el contrato de un microservicio interno o del Core Bancario, el cambio se absorbe en la capa BFF sin obligar a los clientes a actualizar la aplicación en las tiendas (App Store / Play Store), reduciendo el riesgo de rotura de contratos (*contract breaking*).

2. Desacoplamiento de Servicios y Orquestación de Transferencias

El requerimiento indica 3 servicios iniciales:

1. **Servicio de Datos Básicos:** Consulta datos generales del cliente.
2. **Servicio de Movimientos:** Consulta histórico de transacciones.
3. **Servicio de Transferencias:** Orquesta transferencias propias e interbancarias.

Para optimizar rendimiento, disponibilidad y resiliencia, agregamos **3 microservicios estratégicos**:

Nuevo Servicio	Propósito y Justificación
Servicio de Enriquecimiento de Clientes (Customer Profile Enriched Service)	Implementa el patrón API Aggregation / Composition . Consulta el Core bancario (datos básicos) y, bajo demanda o en paralelo, el sistema complementario de datos detallados sin degradar la latencia del core.
Servicio de Notificaciones (Notification Orchestrator)	Consumidor asíncrono de eventos de mensajería para despachar notificaciones Push (Azure Notification Hubs) y SMS/Email (Azure Communication Services) sin bloquear la transacción bancaria.
Servicio de Auditoría Inmutable (Audit Trail Service)	Servicio desacoplado que persiste cada interacción y cambio de estado en una base de datos de auditoría WORM garantizando no repudio.

Patrón para Transferencias Interbancarias y Propias: Saga Orquestada + Compensación

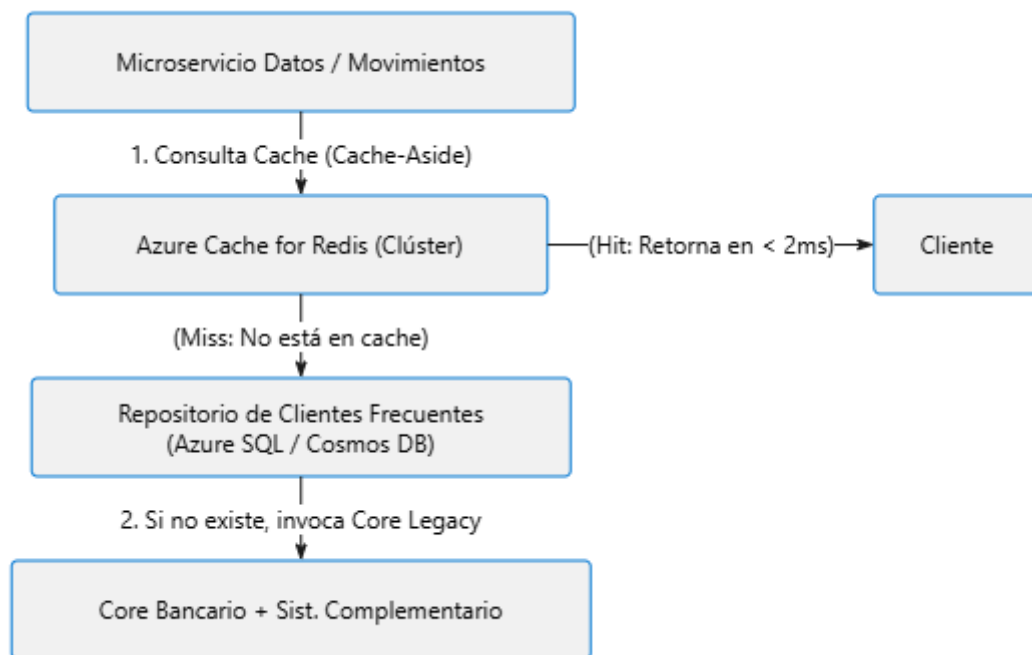
- **El Problema:** Una transferencia interbancaria involucra múltiples sistemas independientes:
 - Débito en la cuenta local (Core Bancario BP).
 - Envío de fondos a cámara de compensación externa (ACH / SPEI / Banco Central).
 - Confirmación / Acreditación en el banco destino.
 - Generación de comprobante y disparo de notificación.

- *Un commit distribuido (2PC - Two Phase Commit) está prohibido en banca moderna porque bloquea recursos y degrada la disponibilidad si el switch interbancario tarda segundos en responder.*
- **Solución: Patrón Saga (Orchestration-based Saga):**
 - El **Microservicio de Transferencias** actúa como el *Saga Orchestrator*.
 - Si la cámara de compensación externa responde con error (rechazo o timeout prolongado), el orquestador ejecuta la **transacción compensatoria**: reversa el débito en la cuenta de origen del Core BP y notifica al usuario.

3. Patrón de Persistencia y Caché para "Clientes Frecuentes"

El requerimiento indica: *"cuenta con un mecanismo de persistencia de información para clientes frecuentes, proponga una alternativa basada en patrones de diseño"*.

Diseño del Patrón Híbrido: Cache-Aside + Read-Through / Write-Through



Componentes y Patrones Involucrados:

1. **Patrón Cache-Aside (Lazy Loading con Redis):**
 - Cuando un usuario consulta su perfil o productos, el servicio verifica en **Azure Cache for Redis (Enterprise Tier con clustering multi-AZ)**.
 - Si hay un *Cache-Hit*, los datos se devuelven en submilisegundos (latencia < 2 ms), protegiendo al Core Legacy de saturación.
 - Si hay un *Cache-Miss*, se leen los datos de la base de persistencia de clientes frecuentes, se escribe el dato en Redis con un **TTL dinámico (ej. 15 minutos)** y se retorna.
2. **Patrón Read-Through / Event-Driven Pre-warming (Cálculo de "Frecuencia"):**

- Un proceso batch o analítico (Azure Functions / Stream Analytics) evalúa el log de auditoría. Si un cliente inicia sesión ≥ 3 veces por semana o transacciona periódicamente, se cataloga como "Cliente Frecuente".
 - Sus datos consolidados y sus últimos 20 movimientos se pre-cargan (*warm cache*) en la base de datos de lectura de alta velocidad (**Azure Cosmos DB** con réplicas de lectura locales o **Azure SQL Database Hyperscale** con Read-Scale out).
3. **Invalidación de Caché vía Eventos (Cache Eviction):**
- Si el cliente realiza una transferencia o actualización de datos, el evento disparado invalida la clave de Redis inmediatamente (`DEL user:{id}:balance`), evitando lecturas sucias (*dirty reads*).

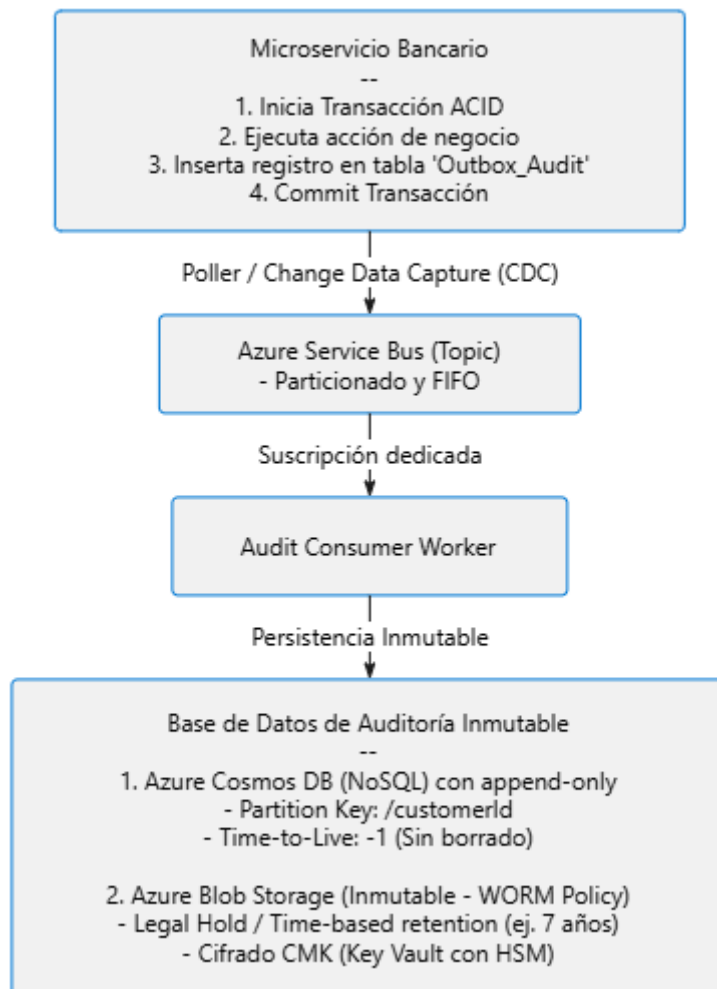
Justificación Técnica de la Estrategia de Caché y Persistencia:

- **Opciones evaluadas:** Consultar siempre el Core Bancario en tiempo real vs. **Capa intermedia distribuida (Redis + Cosmos DB Cache-Aside).**
- **Decisión seleccionada:** **Capa intermedia distribuida con Azure Cache for Redis + Cosmos DB.**
- **Justificación técnica:**
 1. *Protección del Core Bancario (Mainframe / Legacy AS400):* Los Cores bancarios tradicionales cobran por MIPS (Millions of Instructions Per Second) y no escalan elásticamente. Filtrar las lecturas repetitivas mediante Redis y Cosmos DB reduce la carga hacia el Core en más de un 80%, evitando caídas en horas pico (días de quincena o fin de mes).
 2. *SLA de lectura sub-segundo en aplicaciones móviles:* Almacenar los datos de clientes frecuentes en memoria en memoria RAM distribuida (Redis) permite tiempos de respuesta de consulta de saldo y últimos movimientos inferiores a 50 ms en el front-end, mejorando sustancialmente el NPS (Net Promoter Score) del banco.

4. Diseño de la Base de Datos de Auditoría Inmutable

El requerimiento exige registrar todas las acciones del cliente con alta seguridad.

Arquitectura de Auditoría: Patrón Transactional Outbox + Azure Service Bus + Azure Cosmos DB / Synapse



Principios de Diseño de la Solución de Auditoría:

1. **Patrón Transactional Outbox:** Garantiza la atomicidad (*Dual-write avoidance*). La operación bancaria y el evento de auditoría se guardan en la misma transacción de la base de datos local. Un relay de eventos (*Change Data Capture - CDC*) toma el evento y lo publica en **Azure Service Bus Topic** (*audit-events*), asegurando que nunca se pierda un log, incluso ante fallos de red.
2. **Inmutabilidad y No Repudio (Cumplimiento Regulatorio WORM):** Los registros de auditoría se sincronizan hacia **Azure Blob Storage** con directiva de inmutabilidad basada en tiempo (**WORM - Write Once, Read Many**) y bloqueo de retención legal (*Legal Hold*). Ningún rol administrador ni usuario con permisos *Owner* puede modificar o eliminar los registros durante el periodo obligatorio (ej. 7 a 10 años según regulación bancaria).
3. **Cifrado y Cadena de Integridad:** Cada bloque de auditoría incluye el hash SHA-256 del registro anterior, generando una cadena criptográfica auditable que alerta inmediatamente si algún dato histórico intenta ser manipulado.

Estructura del Registro de Auditoría (Schema estándar JSON)

```
{
  "auditId": "9b1deb4d-3b7d-4bad-9bdd-2b0d7b3dcb6d",
  "traceId": "4bf92f3577b34da6a3ce929d0e0e4736",
  "timestampUtc": "2026-09-15T17:15:30.123Z",
  "userId": "usr_998124",
  "channel": "MOBILE_FLUTTER",
  "action": "TRANSFER_INTERBANK",
  "ipAddress": "190.152.45.118",
  "userAgent": "AppBanca/v3.2.1 Android/14",
  "payloadHash": "e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b855",
  "previousRecordHash":
"8f434346648f6b96df89dda901c5176b10a6d83961dd3c1ac88b59b2dc327aa4",
  "status": "SUCCESS",
  "metadata": {
    "sourceAccount": "*****1234",
    "targetBank": "BANCO_XYZ",
    "amount": 150.00,
    "currency": "USD"
  }
}
```

5. Resumen de Patrones de Arquitectura Clave Utilizados en el Proyecto

Patrón de Arquitectura	Dónde se aplica	Beneficio concreto en este banco
BFF (Backend for Frontend)	Entre API Management y Clientes (Móvil / Web)	Payloads a la medida, menor latencia móvil y aislamiento de cambios de contrato.
Transactional Outbox	En todos los microservicios hacia Azure Service Bus	Evita discrepancias entre el estado de negocio y la pista de auditoría/notificaciones.
Saga Orquestada	Microservicio de Transferencias	Control de transacciones distribuidas y compensación automática en transferencias interbancarias fallidas.

Cache-Aside + Read-Through	Servicio de Clientes Frecuentes + Redis	Alivia la saturación del Core Legacy bancario y responde consultas de clientes en < 5 ms.
Circuit Breaker / Retry con Backoff	Conexiones hacia ACH y Sistema Complementario	Evita fallos en cascada si un servicio externo experimenta lentitud (<i>fail-fast</i> con Azure Pollys/Envoy).

PARTE 3: Modelado Arquitectónico C4 para Banco BP

El modelo C4 permite comunicar la arquitectura a diferentes niveles de abstracción. Para cumplir estrictamente con los criterios de evaluación, desarrollaremos los tres primeros niveles requeridos:

1. **Nivel 1: Diagrama de Contexto del Sistema (System Context):** Dirigido a stakeholders y perfiles no técnicos. Delimita el ecosistema global de Banco BP, los actores humanos y todos los sistemas externos interactuantes.
2. **Nivel 2: Diagrama de Contenedores (Container Diagram):** Dirigido a ingenieros y arquitectos. Representa las aplicaciones web/móvil, gateways, bases de datos, buses de mensajería y límites de red en Azure.
3. **Nivel 3: Diagrama de Componentes (Component Diagram):** Detalla la descomposición interna del servicio más crítico del caso: el **Microservicio de Transferencias (Saga Orchestrator)**.

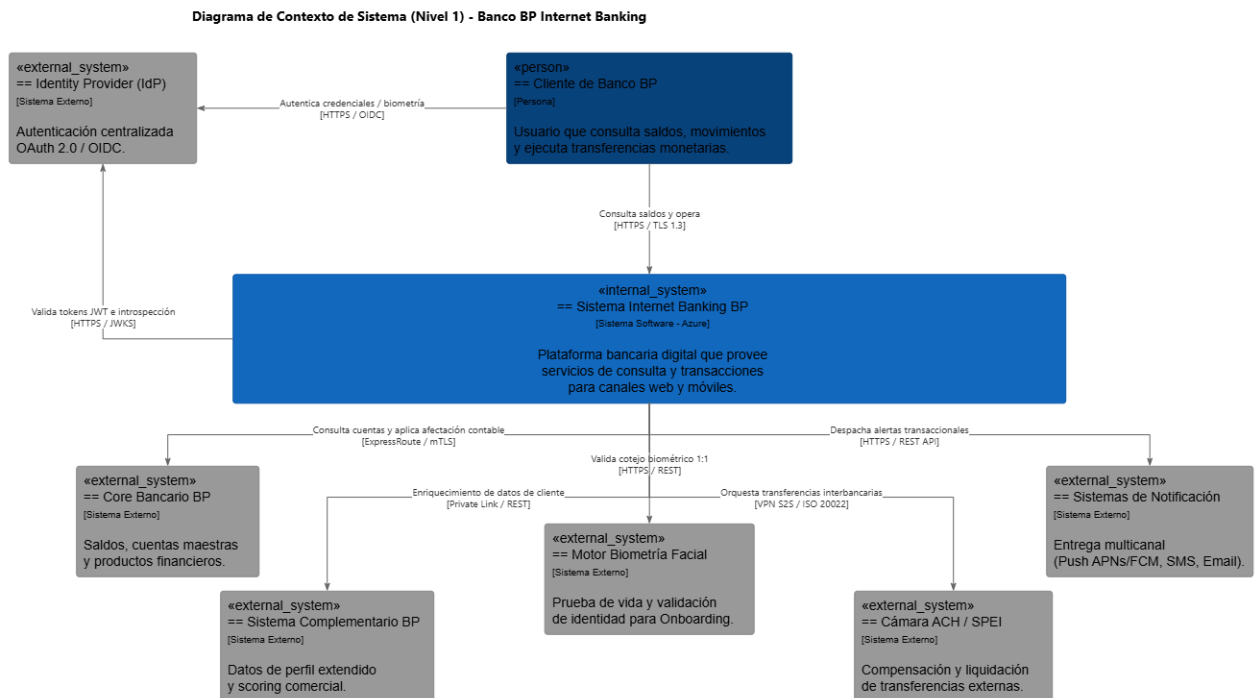
1. Nivel 1: Diagrama de Contexto del Sistema (C1)

Descripción de Actores y Sistemas

- **Cliente Bancario:** Persona natural que consulta saldos, movimientos y ejecuta transacciones financieras desde la web o el móvil.
- **Sistema Banco BP Internet Banking:** La nueva solución de banca digital diseñada sobre Azure.
- **Sistemas Externos Integrados:**
 - *Core Bancario BP:* Sistema legado on-premises que custodia cuentas, saldos contables y ejecuta débitos/créditos locales.
 - *Sistema Complementario BP:* Base de datos de clientes con atributos extendidos, perfil de riesgo y segmentación comercial.

- *Identity Provider (IdP)*: Servicio centralizado de emisión/validación de identidades OAuth 2.0 / OIDC.
- *Motor Biometría Facial / eKYC*: Servicio de verificación de identidad 1:1 y prueba de vida para onboarding.
- *Cámara de Compensación (ACH / SPEI)*: Red financiera interbancaria nacional para liquidación de fondos.
- *Proveedores de Notificación*: Redes push (Apple APNs, Google FCM) y pasarelas de mensajería (SMS/Email vía Azure Communication Services).

Diagrama de Contexto (C1)



2. Nivel 2: Diagrama de Contenedores (C2)

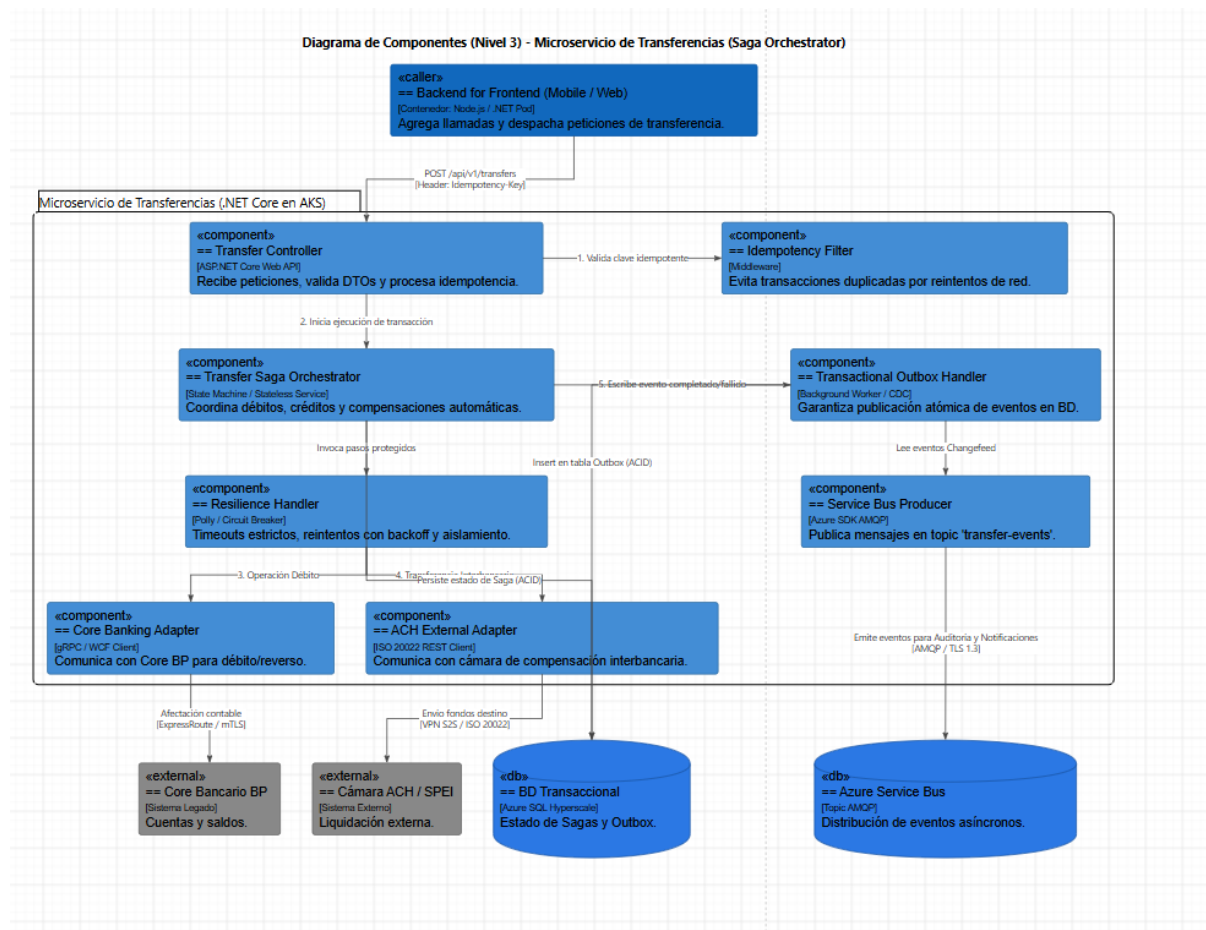
Descripción de Límites e Infraestructura

- **Zona de Borde (Edge Ingress): Azure Front Door** (WAF OWASP L7, mitigación DDoS, terminación TLS 1.3) y **Azure API Management** (orquestración perimetral, políticas de throttling, validación JWT).
- **Zona de Cómputo (VNet Privada en AKS):**
 - *Mobile BFF & Web BFF*: Adaptadores de canal para optimización de cargas y agregación de llamadas.
 - *Microservicios de Negocio*: Microservicio Datos Básicos, Movimientos, Transferencias (Saga), Notificaciones y Auditoría.
- **Capa de Persistencia y Caché:**
 - *Azure Cache for Redis*: Clúster en memoria para respuestas < 2 ms en clientes frecuentes.

Descomposición Interna:

1. **Transfer Controller:** Expone endpoints REST/gRPC protegidos con validación de modelo y políticas de idempotencia (**Idempotency-Key**).
2. **Transfer Orchestrator (Saga Coordinator):** Máquina de estados que ejecuta las fases de la transacción:
 - Bloqueo/débito de fondos en la cuenta de origen (Core BP).
 - Envío de instrucción de crédito a la cámara ACH.
 - Ejecución de compensación (reverso de débito) ante rechazo o timeout en ACH.
3. **Outbox Event Publisher:** Garantiza atomicidad local guardando el evento de transferencia en una tabla **Outbox** dentro de la misma transacción de base de datos antes de publicarlo.
4. **Resilience Policy Handler:** Circuit Breaker, Retries exponenciales y Timeouts implementados con Polly / Envoy Mesh.
5. **Adapters:** Core Adapter (ExpressRoute), ACH Gateway Adapter (mTLS), y Service Bus Producer.

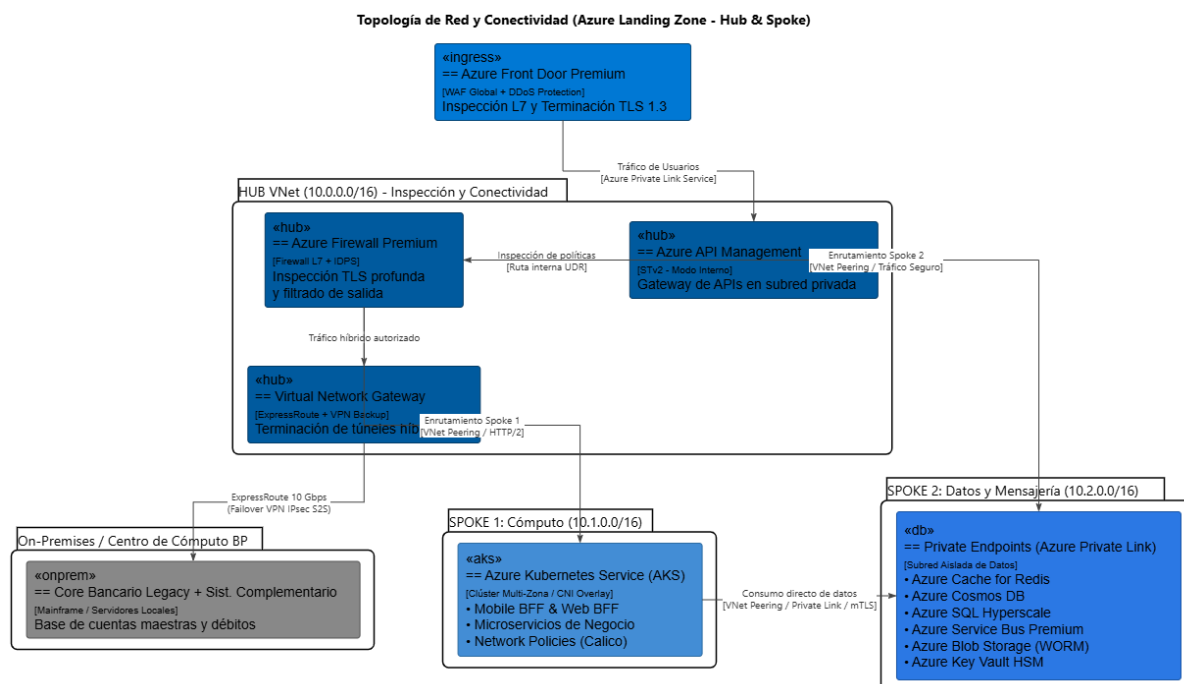
Diagrama de Componentes (C3)



PARTE 4: Infraestructura Cloud, Alta Disponibilidad (HA), Recuperación ante Desastres (DR), Seguridad Zero Trust y Gestión de Costos

1. Topología de Red y Arquitectura de Conectividad (Azure Landing Zone)

Para garantizar aislamiento financiero, cumplimiento regulatorio e inspección de tráfico centralizada, se implementa una topología de red **Hub-and-Spoke** corporativa alineada con el Cloud Adoption Framework (CAF).



Justificación Técnica Doble de la Red

- **Opciones evaluadas:** Conectividad plana directa con Service Endpoints públicos vs. **Hub-and-Spoke con Azure Firewall Premium + Private Endpoints (Azure Private Link)**.
- **Decisión seleccionada:** Hub-and-Spoke con Azure Firewall Premium y Private Endpoints.
- **Justificación técnica doble:**
 1. *Aislamiento perimetral y prevención de exfiltración de datos:* Con Private Link, los servicios PaaS (Cosmos DB, Redis, Service Bus, Storage) no exponen direcciones IP públicas ni registros DNS públicos accesibles desde la red global. El tráfico permanece 100% dentro del backbone de Microsoft, eliminando vectores de ataque de escaneo perimetral.

2. *Inspección profunda de tráfico (IDPS L7) y cumplimiento normativo bancario:* Azure Firewall Premium con TLS Inspection descifra e inspecciona el tráfico saliente (*egress*) hacia el Core Legacy y APIs externas (cámaras de compensación, biometría), garantizando la no exfiltración de datos no estructurados y detectando tráfico de comando y control (C2).

2. Estrategia de Alta Disponibilidad (HA) y Recuperación ante Desastres (DR)

La banca electrónica requiere un diseño de disponibilidad estricto para evitar pérdidas financieras o daño reputacional.

A. Métricas de Resiliencia Comprometidas

- **RTO (Recovery Time Objective):** < 15 minutos (tiempo máximo para restaurar el servicio en la región secundaria).
- **RPO (Recovery Point Objective):**
 - Para consultas de saldo y movimientos: < 1 minuto (replicación asincrónica geo-distribuida).
 - Para transacciones financieras y auditoría: 0\$ (RPO nulo local; no se tolera pérdida transaccional gracias a la sincronización síncrona multi-zona).
- **SLA de la Solución Global:** 99.99% (máximo 52 minutos de inactividad no planificada al año).

B. Matriz de Resiliencia por Componente

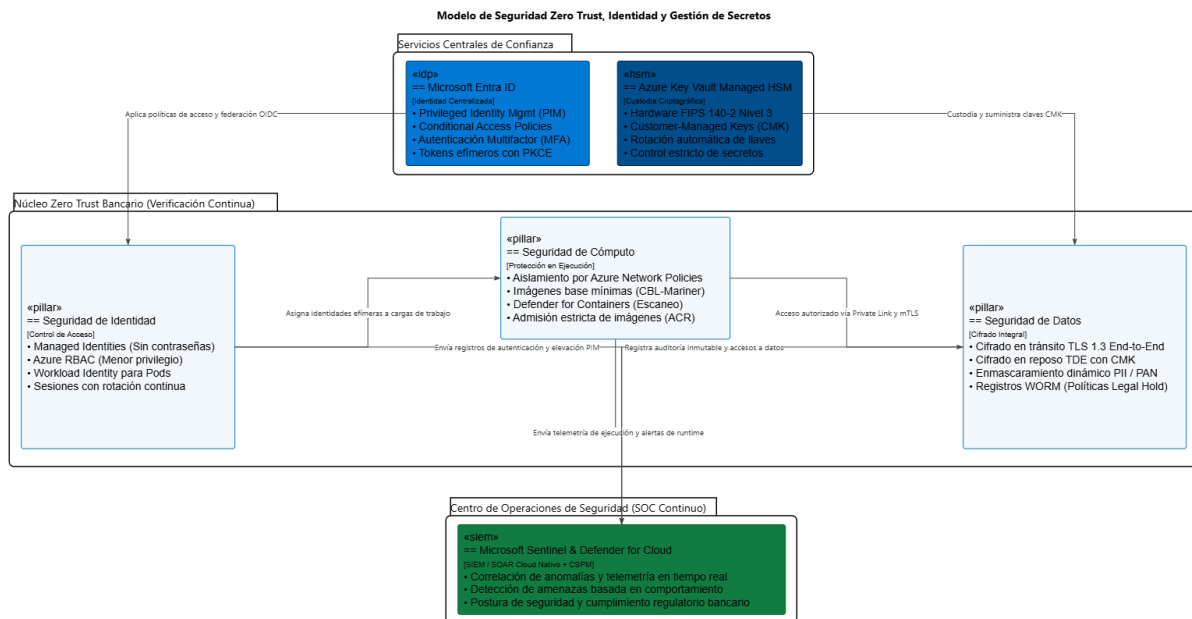
Componente	Nivel Local (Alta Disponibilidad - HA)	Nivel Regional (Disaster Recovery - DR)	Mecanismo de Failover
Capa de Entrada (Ingress)	Azure Front Door activo globalmente con Anycast DNS multi-borde.	Despliegue global en el borde perimetral de Microsoft.	Automático en < 15 segundos mediante Health Probes L7.

Cómputo (AKS - BFFs y Microservicios)	Clúster AKS multi-zona distribuido equitativamente entre las 3 Zonas de Disponibilidad (AZs) .	Clúster AKS pasivo en la región secundaria (<i>Hot Standby</i> con escalado mínimo de pods a 1 réplica).	Enrutamiento de Front Door conmuta el tráfico hacia el APIM de la región de contingencia.
Caché (Azure Cache for Redis)	Nivel Enterprise con réplicas activas zonales (AZ 1, 2 y 3) con failover automático en memoria.	Despliegue independiente en la región secundaria.	Ante desastre regional, la caché de la región secundaria se pre-calienta (<i>cache pre-warming</i>) bajo demanda.
Persistencia Transaccional (Azure SQL Hyperscale)	ZRS (Zone-Redundant Storage) con réplica secundaria local sincrónica de lectura activa.	Geo-Replication / Failover Groups asincrónicos hacia la región par (Paired Region).	Failover Group conmutado automáticamente o asistido en \$<2\text{ minutos}\$.
Persistencia NoSQL (Azure Cosmos DB)	Multi-AZ enabled con 3 réplicas locales sincrónicas.	Multi-Region Replication activa hacia la región secundaria con consistencia de sesión o limitada (<i>Bounded Staleness</i>).	Conmutación por prioridad de región automática configurada en el SDK.

Mensajería (Azure Service Bus)	Tier Premium con soporte para Availability Zones locales.	Geo-Disaster Recovery (Geo-DR) de metadatos acoplado a topics secundarios.	Conmutación por DNS alias en el SDK AMQP.
Almacenamiento de Auditoría (Blob WORM)	Redundancia ZRS inmutable con directiva WORM basada en tiempo.	GZRS (Geo-Zone-Redundant Storage) para copias inmutables replicadas a cientos de kilómetros.	Replicación asincrónica en el almacenamiento par secundario.

3. Modelo de Seguridad Zero Trust, Identidad y Gestión de Secretos

La arquitectura adopta el principio fundamental de Zero Trust: *"Nunca confiar, verificar siempre"*.



Componentes de Seguridad Implementados:

- **Autenticación sin credenciales (Zero Hardcoded Secrets):**

- Ningún microservicio ni aplicación contiene strings de conexión, passwords o llaves en código fuente o variables de entorno.
- Se utiliza **Azure Workload Identity** en AKS: cada Pod asume una Managed Identity de Entra ID mediante federación OIDC contra el clúster, solicitando tokens efímeros para conectarse a Cosmos DB, Service Bus o SQL.
- **Custodia de Claves Criptográficas:**
 - Implementación de **Azure Key Vault Managed HSM (Hardware Security Module)** con certificación FIPS 140-2 Nivel 3.
 - Todas las bases de datos (SQL Hyperscale, Cosmos DB, Blob Storage) aplican cifrado en reposo gobernado por **Customer-Managed Keys (CMK)**, garantizando que el banco mantenga el control exclusivo sobre el descifrado de los datos.
- **Gobernanza y Privilegio Mínimo:**
 - **Microsoft Entra PIM (Privileged Identity Management):** Todo acceso administrativo a suscripciones o infraestructura requiere elevación Just-in-Time (JIT), aprobación dual y registro justificado de tickets, caducando en un lapso de 1 a 4 horas.
 - **Azure Policy:** Directivas enforce en tiempo de ejecución (denegar IPs públicas en subredes de AKS, exigir ZRS mandatorio en almacenamiento y bloquear versiones TLS inferiores a 1.3).

4. Observabilidad, Monitoreo y Auto-Healing (Excelencia Operativa)

Para garantizar la estabilidad del servicio y detectar anomalías antes de que impacten a los usuarios finales:

- **Telemetría Distribuida y Trazabilidad:**
 - Instrumentación de los microservicios con **OpenTelemetry (OTel)** y exportación nativa a **Azure Application Insights**.
 - Cada solicitud en la aplicación móvil o web recibe un encabezado **traceparent** (estándar W3C) que viaja por Front Door, APIM, BFF, Microservicios y Service Bus, permitiendo a los ingenieros rastrear un error transaccional de extremo a extremo en el mapa de dependencias de Application Insights.
- **Detección de Amenazas y SIEM:**
 - Centralización de logs (Azure Activity, NSG Flow Logs, trazas de auditoría WORM, logs de APIM) en un área de trabajo unificada de **Azure Log Analytics**.
 - **Microsoft Sentinel:** Correlaciona eventos mediante reglas analíticas para identificar patrones anómalos (por ejemplo: transferencias concurrentes desde IPs en continentes distintos en menos de 5 minutos, o intentos de fuerza bruta sobre el API Gateway).
- **Mecanismos de Auto-Healing y Autoescalado Elástico:**
 - **HPA (Horizontal Pod Autoscaler) + KEDA:** Escala los pods de BFF y Microservicios en función de CPU/Memoria y de la profundidad de colas de Azure Service Bus (escalado reactivo en ráfagas transaccionales).
 - **Cluster Autoscaler en AKS:** Añade nodos virtuales en segundos sobre los conjuntos de escalado de máquinas virtuales (VMSS).

- **Liveness & Readiness Probes:** Kubernetes reinicia de inmediato pods zombis o satura el tráfico solo hacia réplicas activas que hayan completado su calentamiento de memoria.

5. Estrategia de Optimización y Eficiencia de Costos (FinOps)

El requerimiento indica que se cuenta con presupuesto, pero el rol de arquitecto exige justificar el gasto y maximizar el Retorno de Inversión (ROI).

Estrategia FinOps	Servicio Aplicado	Mecanismo de Ahorro y Justificación
Azure Savings Plans & Instancias Reservadas (RI)	AKS Node Pools (VMs) y Azure SQL Hyperscale	Compromiso a 1 o 3 años para la carga base (<i>baseline</i>), reduciendo costos operativos de cómputo entre un 40% y un 65% frente a tarifas Pay-As-You-Go.
Escalado Elástico por Demanda (Scale-to-Zero)	Workers de Notificación y Auditoría	Uso de KEDA en AKS o Azure Container Apps: durante las horas de la madrugada (tráfico mínimo), los pods consumidores bajan a réplicas mínimas, ahorrando recursos de CPU/RAM.
Políticas de Ciclo de Vida en Almacenamiento (Tiering)	Azure Blob Storage (Auditoría WORM)	Reglas automatizadas: los eventos de auditoría se guardan en el nivel Hot durante 30 días, pasan al nivel Cool del día 31 al 365, y se archivan en el nivel Archive a partir del segundo año (reduciendo el costo de almacenamiento por GB en más de un 80% manteniendo el cumplimiento legal).

Azure Hybrid Benefit (AHB)	Nodos Windows/SQL Server	Reutilización de licencias on-premises existentes con Software Assurance de Banco BP para descontar el licenciamiento en la nube.
-----------------------------------	--------------------------	---

PARTE 5: Conclusiones Técnicas y Hoja de Ruta de Adopción (Roadmap)

1. Conclusiones de la Arquitectura Propuesta

- **Resiliencia y Desacoplamiento Garantizado:** La combinación de API Management y el patrón BFF aísla los canales móviles y web de los cambios en el Core Bancario, optimizando los payloads y la experiencia en redes celulares deficientes.
- **Consistencia Financiera sin Bloqueos (2PC Free):** El patrón Saga orquestado junto con transacciones compensatorias y Transactional Outbox elimina el riesgo de estados inconsistentes entre las cuentas locales y las cámaras de compensación interbancarias, protegiendo la disponibilidad y evitando bloqueos distribuidos prolongados.
- **Cumplimiento Regulatorio y Seguridad por Diseño (Zero Trust):** El uso de identidades de carga de trabajo efímeras (Azure Workload Identity), cifrado con claves en custodia de hardware (Managed HSM) y almacenamiento inmutable con retención WORM garantiza el cumplimiento estricto de normativas como PCI-DSS, GDPR/LOPD y supervisión bancaria sin puntos ciegos.
- **Protección de Inversión y Eficiencia Operativa:** Mediante la arquitectura híbrida de caché (Redis + Cosmos DB) se mitiga en más de un 80% la saturación de transacciones repetitivas sobre el Core On-Premises, mientras que las reservas de capacidad (Savings Plans) y el autoescalado reactivo con KEDA optimizan el gasto financiero de nube.

2. Hoja de Ruta de Implementación Sugerida (Fases de Despliegue)

- **Fase 1: Cimientos de Nube y Conectividad Híbrida**
 - Despliegue de la Landing Zone Hub-and-Spoke vía Terraform / Bicep.
 - Configuración de ExpressRoute, Azure Firewall Premium y Private Endpoints.
 - Implementación de políticas de gobernanza en Azure Policy y configuración de Microsoft Entra ID / PIM.
- **Fase 2: Plataforma de Cómputo y Núcleo de Microservicios**
 - Aprovisionamiento del clúster privado AKS multi-zona e integración de Workload Identity.
 - Implementación de Azure Cache for Redis Enterprise y Azure Service Bus Premium.

- Despliegue de los BFFs (Mobile y Web) y los microservicios core (Datos Básicos, Movimientos y Transferencias).
- Fase 3: Integraciones Críticas, Auditoría y Seguridad
 - Integración del pipeline de auditoría outbox con Azure Blob Storage WORM y HSM.
 - Pruebas de integración segura con el Core Bancario On-Premises y cámaras ACH.
 - Configuración del SIEM Microsoft Sentinel y telemetría distribuida con OpenTelemetry.
- Fase 4: Pruebas de Resiliencia, DR y Salida a Producción
 - Pruebas de inyección de fallos (Chaos Engineering) para simular caídas en zonas de disponibilidad.
 - Simulacro formal de Disaster Recovery (failover de Front Door y bases de datos en < 15 minutos).
 - Puesta en marcha escalonada (Canary / Blue-Green Deployment) iniciando con un grupo piloto de clientes.